

CloudCorp Projektuppgift

Inledning	2
Del – 1: Incidentanalys.....	2
Möjlig attackväg av hotaktör.....	3
Rotorsak till Incident - “S3-Bucket”	3
Befintliga Felkonfigurationer	4
Arkitektur:	4
Lagring:	4
IAM:	5
Trafik:.....	5
Övrigt:	5
Konsekvenser	6
Del 2 – Ny Arkitektur (Bild)	6
Enheter	7
Region 1 (Aktiv)	7
Region 2 (Standby)	7
Route 53.....	7
Internet Gateway	8
AWS WAF	8
Application Load Balancer	8
Publika Subnät	8
NAT Gateway	8
Privata Subnät (applikation)	8
Lambda Backend	8
Privata subnät (Data).....	8
S3-Bucket	9
S3 Gateway Endpoint	9
Del 3 - Nätverk och Säker Design	9
Region 1 & 2.....	9
Nätverkssegmentering	10
Defense in Depth	10
Hög Tillgänglighet.....	10
Least Privilage & IAM Säkerhet	11

Trafikhantering.....	11
Kryptering och Skydda av Data	12
Säker Administration	12
Del 4 – Implementation.....	12
Nätverksinfrastruktur	12
Publika Subnät.....	13
Privata Subnät (App).....	13
Privata Subnät (Data)	13
S3-Bucket.....	13
IAM	14
Lambda Backend	14
Route 53.....	14
Del 5 - Säkerhetsanalys	14
Risk 1 – IAM & Övriga Felkonfigurationer.....	14
Risk 2 – NAT Gateway	15
Risk 3 – AWS Beroende	15
Risk 4 – Webbapplikation Kompromettering	15
Risk 5 - Bristande Övervakning & Loggning	16
Resonemang Kring Säkerhetsrisker	16
Del 6 - Kostnad och molnmodeller.....	16
SaaS (Software as a Service)	16
IaaS (Infrastructure as a Service)	17
PaaS (Platform as a Service)	17
Kostnader.....	17

Inledning

Företaget CloudCorp, liknande många företag idag, erbjuder en webbtjänst. Detta är ett så kallat SaaS-företag (Software as a Service) och detta innebär att de hanterar en mängd kunddata via deras egna servrar och enheter. CloudCorp har nu bestämt sig för att migrera från sina egna servrar till Amazons molntjänst, AWS (Amazon Web Services). Företaget är oerfarna med molnlösningar men lyckas ändå att få sin webbtjänst att fungera med AWS och hanterar numera allt gällande webbtjänsten via AWS.

Efter denna migration till AWS har CloudCorp utsatts för en dataläcka där känslig information, främst kunddata, laddades ner av en hotaktör. Denna hotaktör lyckades även att koppla sig upp direkt mot CloudCorp:s webbtjänst.

I denna rapport kommer vi att ta en titt på följande:

- **Incidentanalys:** Dataläckan, hur den genomfördes, varför den gick att genomföra & konsekvenserna som uppstod.
- **Förbättrad arkitektur:** Diagram och säkerhetstänk.
- **Implementation:** Vilka resurser som används i den förbättrade arkitekturen, varför de används och hur de skapas.
- **Säkerhetsanalys:** En titt på den förbättrade arkitekturen/resurserna från ett säkerhetsperspektiv.
- **Kostnader och molnmodeller:** En titt på vilka olika molnmodeller som finns och vad som påverkar kostnaderna av att använda en molntjänst.

Del – 1: Incidentanalys

CloudCorp:s molnmiljö drabbades av ett dataintrång, där en angripare kunde komma åt och ladda ner känslig information, främst kunddata. Enligt följande information från uppgiftens instruktioner “En angripare hittade den publika S3-Bucketen” är det uppenbart att angriparen lokaliserade den “publika S3-Bucketen” och därifrån lyckades ladda ner känslig kunddata. CloudCorp:s nuvarande konfiguration bryter mot både Least Privilege & Defense in Depth principerna.

Möjlig attackväg av hotaktör

Det finns potentiella sätt en hotaktör skulle kunna lokalisera denna publika S3-Bucket, CloudCorp:s webbtjänst använde för lagring av kunddata. Många av dessa sätt kräver inte kunskaper av företagets inre struktur eller begär en högre ankomst inom företagets system. Dessa sätt bygger på hur AWS molntjänst interagerar med lagring, mer specifikt, en S3-Bucket.

En av de troligare sätt lagringsenheten hittades via webbläsarens gränssnitt. När webbtjänsten använder sig av resurserna inom lagringsenheten så kan detta ses via en webbläsares utvecklingsverktyg. På så sätt kan adressen till lagringsenheten hittas, i form av en URL och där med utnyttjas.

Om webbplatsen i fråga skulle använda sig av ett scripting-språk som JavaScript skulle det finnas en chans att lagringsenhetens namn eller URL finns med i konfigurationsfilerna i någon form och på så sätt hittats.

Utöver detta finns det otaliga sorters mjukvara med förmågan att hitta dessa adresser genom att scanna webbplatser. Detta kan åstadkommas genom en kombination av att AWS skapar förutsägbara adresser till dessa lagringsenheter och att skapa en ordlista av fraser samt ord relaterat till företaget, med förhoppningen att mjukvaran lyckas hitta en resurs med ett liknande namn.

Rotorsak till Incident - "S3-Bucket"

Som uppgiften nämner så är CloudCorp inte erfarna med molnsäkerhet och har flera felkonfigurationer i både sin webbtjänst och resurserna kring tjänsten i sig. Denna rapport kommer att gå igenom dessa men först så tar vi en titt på den direkta orsaken till incidenten.

Företaget spara/lagrar sin kunddata i en S3-Bucket via AWS tjänsten. Denna Bucket är publikt läsbar, vilket innebär att vem som helst kan ta del av informationen i den. Detta är ett problem från ett säkerhetsperspektiv eftersom att obehöriga personer får åtkomst till känslig information olika former. Detta inkluderar fullständiga namn, Email-adresser, telefonnummer, övrig kontoinformation & möjligtvis även betal och bankuppgifter.

Problem är då att CloudCorp:s felkonfigurerade S3-Bucket tillåter vem som helst att ta del av informationen inom den. Detta borde åtgärdas genom att begränsa de allmänna rättigheterna till den befintliga informationen som sparas/lagras i S3-Bucketen. Detta kan göras genom att ändra den nuvarande publika statusen till att inte vara publik, för att sedan där ifrån tilldela specifika rättigheter till S3-Bucketen vid behov.

Befintliga Felkonfigurationer

Nedan beskrivs den befintliga designen/konfigurationen av deras webbtjänst i AWS och varför den inte är duglig från ett säkerhetsperspektiv. Fokuset ligger i att identifiera vad som är fel och varför det är det.

Arkitektur:

- En VPC med endast ett publikt subnät.
- En EC2-instans (frontend + backend) med publik IP.
- Säkerhetsgrupper med öppna portar (80 och 22 till 0.0.0.0/0)
- Ingen nätverkssegmentering eller Bastion Host.

En VPC med endast ett publikt subnät utgör en stor säkerhetsrisk på grund av att nätverkets resurser blir direkt exponerade mot internet på grund av att de har publika IP-adresser och kan ta emot trafik direkt från internet. För att uppnå en mer moderna och säker arkitektur borde nätverkets resurser placeras i privata subnät för att minimera attackytan mot dessa resurser.

Faktumet att EC2 instansen agerar som både Frontend & Backend innebär att om tjänsten komprometteras så kan en hotaktör nå både Frontend & Backend. I en modernare arkitektur så är dessa separerade och ofta i olika privata subnät för att separera funktionerna och på så sätt göra det svårare att attackera nätverkets olika enheter.

De säkerhetsgrupper som finns tillåter trafik från internet mot företagets webbtjänst via port 80 & 22. Detta innebär att enheter kan kommunicera med webbtjänsten via dessa portar. Port 80 tar emot icke krypterad trafik som kan lätt avlyssnas och bör bytas ut mot port 443 som tar emot trafik krypterat av TLS och är ett bättre alternativ. Port 22 borde, under inga omständigheter, ta emot trafik direkt från internet och borde egentligen inte vara öppen över huvud taget, eftersom det finns bättre och säkrare alternativ.

Lagring:

- S3-Bucket med kunddata
- Public Read aktiverad
- Ingen kryptering eller Access Policies

Lagring av kunddata i en S3-Bucket är inte en rekommenderat sätt att lagra all kunddata. En S3-Bucket är ett bra sätt att lagra filer av olika slag, men inte data som betaluppgifter, lösenord och email adresser. I detta fall saknades även grundläggande säkerhetsåtgärder som tillät nedladdning av kunddata som ska vara konfidentiell. Lagringsenheten hade publik read aktiverad vilket tillät detta dataintrång att ske. Lagringen saknade även Access Policies som dikterar vem/vilka som har tillgång till data inom enheten och var där för också bidragande till varför intrånget var möjligt.

IAM:

- En IAM user med *full access* till S3
- Ingen *Least Privilege*

CloudCorp nuvarande konfiguration har endast en IAM användare med full åtkomst. Om denna användares autentisering komprometteras skulle en hotaktör få åtkomst till hela Cloud-miljön och alla enheter/tjänster inom den. CloudCorp behöver skapa flera IAM användare med privilegier baserat på Least Privilege principen vilket minskar risken för att komprometterade användare förmåga att påverka Cloud-miljöns system och enheter.

Trafik:

- Direkt från internet till EC2
- Ingen *Loadbalancer*

I nuläget är CloudCorp:s webbtjänst direkt exponerad mot internet. Detta gör det enklare för hotaktörer att identifiera möjliga attackvägar och påverka webbtjänsten på olika sätt. Detta är en säkerhetsrisk och bör undvikas genom att placera en enhet framför tjänsten som är kapabel till att filtrera och kontrollera trafik innan den når tjänsten. Detta kan göras på olika sätt men kommer att göras med en Loadbalancer i det senare diagrammet. En Loadbalancer minskar också belastningen på tjänsten.

Övrigt:

- Ingen *Loggning*
- Ingen kostnadsövervakning

I övrigt har Cloud-miljön ingen loggningsfunktion som skulle kunna gett en insyn på hur hotaktören bar sig åt för att lokalisera S3-Bucketen och se vilken data som laddades ner. Loggning av miljön hade underlättat säkerhetsarbetet genom att tillåta företaget att se hur attacken utfördes och då ge väsentlig information angående hur detta kan åtgärdas.

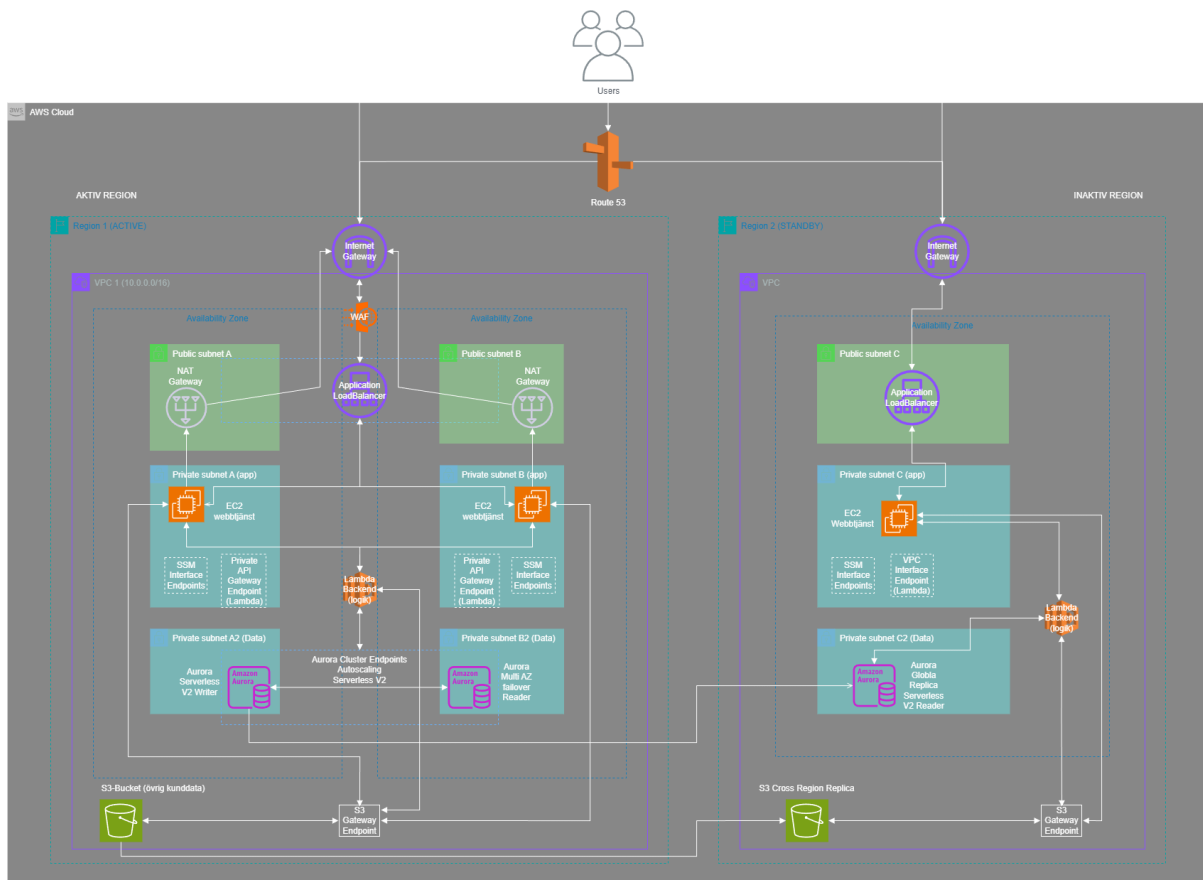
Konsekvenser

Stulen kunddata kan innebära en större mängd av olika saker som alla i slutändan påverkar delar av [CIA-triaden](#). Den första påverkan som direkt kopplas till den stulna kund-datan är konfidentialiteten av informationen. När datan blir stulen tappar företaget kontroll över informationen och kan därmed inte garantera informationens konfidentialitet. Beroende på vad för information som blev stulen skulle ytterligare attacker kunna mot företagets webbtjänst utföras. Om inloggningsinformation av vanliga användare blev stulen skulle en hotaktör kunna ta sig in på personliga konton för att sedan agera i någon annans namn och även ändra på den befintliga informationen kopplat till kontot. Och på så vis begränsa användarens förmåga att använda sitt eget konto samt att informationen kopplat till kontot inte längre stämmer överens med verkligheten. Detta påverkar då alla delar av CIA-triaden, konfidentialiteten, integriteten & tillgängligheten.

Denna incident kan också få juridiska konsekvenser kopplat till GDPR-lagen. Organisationer och företag som hanterar personuppgifter är skyldiga att använda sig av lämpliga säkerhetsåtgärder för att skydda sina personuppgifter. I detta fall fanns inga säkerhetsåtgärder som skyddade informationen från att laddas ner av vem som helst. Detta innebär att CloudCorp skulle kunna behöva betala böter, på stora mängder pengar eller drabbas av andra juridiska konsekvenser.

En dataläcka som denna kan också påverka företagets rykte och relation till sina kunder. När kunderna blir medvetna om att företaget inte lyckats skydda deras personliga information och blir utsatta för de övriga konsekvenser som denna dataläcka gjort möjlig, tappar de förtroendet för företaget och sannolikt väljer att använda sig av en konkurrents tjänst istället. Detta påverkar också potentiella kunder syn av företaget och kan då gå miste om framtida användare.

Del 2 – Ny Arkitektur (Bild)



Enheter

Sammanfattning av enheterna i diagrammet och vad deras funktion/funktioner är.

Region 1 (Aktiv)

- Primär produktionsregion
- Hanterar aktiv trafik och databasskrivningar

Region 2 (Standby)

- Reservregion för disaster recovery.
- Tar över vid större driftstörningar i region 1.

Route 53

- Hanterar DNS och dirigerar användare till rätt AWS-region.
- Används för tillgänglighet och failover mellan regioner.

Internet Gateway

- Ger resurser i det publika subnätet åtkomst till internet.
- Krävs för inkommande och utgående trafik.

AWS WAF

- Filtreerar och skyddar webbtrafik.

Application Load Balancer

- Tar emot inkommande trafik från användare.
- Distribuerar trafik mellan flera EC2 instanser.
- Förbättrar skalbarhet och tillgänglighet.

Publika Subnät

- Består av NAT Gateway och Application Load Balancer.
- Fungerar som kontrollerad ingång till miljön.

NAT Gateway

- Ger EC2 instans internet åtkomst.
- Tillåter endast utgående trafik.

Privata Subnät (applikation)

- EC2 webbserver (webbtjänst).
- SSM Interface Endpoint (tillåter SSM).
- Private API Gateway Endpoint (tillåter kommunikation med Lambda).

Lambda Backend

- Kör serverless backend-logik.
- Består av flera lambda funktioner.

Privata subnät (Data)

- Aurora Serverless V2 databas.
- Aurora Serverless V2 reader.
- Aurora Serverless V2 Global region replica.
- Lagrar kunddata.

S3-Bucket

- Lagrar kunddata (filer).
- Cross-Region Replica (backup).

S3 Gateway Endpoint

- Tillåter privat åtkomst mellan VPC och S3.
- Trafiken går via AWS, inte internet.

Del 3 - Nätverk och Säker Design

Denna molnarkitektur har skapats med följande saker i åtanke, säker, hög tillgänglighet, skalbarhet, kostnad och minimering av attackyta. Poängen med detta är att åtgärda de säkerhetsbrister i den nuvarande molnmiljön, och samtidigt implementera moderna säkerhets principer som Least Privilege & Defense in Depth. Arkitekturen bygger på en tydlig nätverkssegmentering, flera lager av skydd, strikt åtkomsts kontroll, privata resurser och kostnadsmedvetenhet för att skydda företagets kunddata och tjänster.

Region 1 & 2

Cloudmiljön är uppdelad i två regioner. Region nummer 1, den aktiva regionen, ansvarar för webbtjänstens dagliga drift, och region 2, som agerar som en standby/backup. Det är till region 1 som all trafik är menad att skickas till. Denna region ansvarar för den dagliga driften och underhållet av CloudCorp:s webbtjänst. Regionen består av ett större nätverk (VPC), och innehåller två delar (AZ). Detta är främst för att se till att miljön har redundans och klarar av att bibehålla funktion även om någon del av nätet skulle sluta fungera. Om AZ 1 skulle sluta att fungera så skulle AZ 2 ta över genom att trafiken skickas till den via en Loadbalancer.

Region 2 är främst en backup region, och kommer inte att vara “på” för att spara på kostnader, men kommer slås på om systemet märker att region nummer 1 har tappat funktion. Region 2 har samma struktur som region 1, men endast en AZ.

Nätverkssegmentering

En av de viktigare delarna av ett säkert nätverk är hur man har valt att segmentera det. I CloudCorp:s nuvarande Cloudmiljö finns endast ett publikt subnät och inga privata subnät, vilket innebär att deras tjänst ligger i det publika nätet och kan nås direkt från internet.

Denna nya lösning har delat upp nätverket i flera delar. Vi har ett publikt subnät med ytterligare två privata subnät bakom. Denna lösning tillåter för en uppdelning av nätverkets interna delar och separerar tjänster och funktioner. På så vis kan vi säkerställa att komprometterade delar av nätverket förblir isolerade från varandra om det utsätts och hotaktör lyckas ta sig in. Denna separation gör också att attackytan minskas och därmed minskar chansen att en attack lyckas.

Defense in Depth

Arkitekturen bygger på principen, Defense in Depth, vilket innebär att flera säkerhetslager används samtidigt för att skydda nätverket/molnmiljön, istället för att förlita sig på enstaka skyddslager.

Det första skyddslagret består av en Route 53 & AWS WAF som filtrerar inkommande trafik innan den tar sig in i nätverket. WAF blockerar även skadlig trafik och skyddar mot vanligare webbattacker som XSS och SQL-injektion. Därefter tar sig trafiken in i en Loadbalancer som agerar som ytterligare ett skyddslager och som sedan dirigerar trafiken mellan våra olika EC-2 instanser (webbtjänsten) baserat på trafikmängd som då minskar belastningen på tjänsten.

Härefter finns även privata subnät, Security groups, IAM-policies och kryptering som ytterligare begränsar ankomst och skyddar nätverkets resurser. På så sätt skyddas nätverkets resurser och tjänster och begränsar en hotaktörs förmåga att attackera systemet, även om de lyckas ta sig in.

Hög Tillgänglighet

Miljön är designad för hantera potentiella fel utan att dessa fel skulle påverka webbtjänstens funktion och användning. Region 1 har två Availability Zones som båda fungerar separat med kan “kliva in” och hjälpa den andra zonen vid behov. Om AZ 1 får

ett fel i sin EC2-instans så kommer trafiken dirigeras till AZ 2 och gå via den tjänsten stället. Databasen Aurora som innehåller CloudCorp:s kunddata har också en liknande funktion som tillåter databasen i AZ 2 att ta över vid behov och vice versa.

Både Aurora (databas) och S3-Bucket har en cross-region replica som ser till att spara data liggandes i den aktiva regionen till den inaktiva som då alltid ser till att en backup av all kunddata, båda filer och övrig information.

Least Privilege & IAM Säkerhet

Den nya arkitekturen använder sig av Least Privilege principen, vilket innebär att tjänster och resurser endast får tillgång till den behörighet som krävs för att utföra sina uppgifter. Istället för en IAM-användare med fullständiga rättigheter bör flera IAM roller skapas som endast får tillgång till de rättigheter som krävs för att utföra sina uppgifter. Detta innebär också att enheter/resurser inom nätverket endast får tillgång till de enheter de behöver kommunicera med. Dessa rättigheter demonstreras i diagrammet via pilarna mellan enheter.

Detta minskar potentiella konsekvenser av komprometterade autentiseringsuppgifter eftersom hotaktörer inte automatiskt får ankomst till hela Cloud-miljön.

Trafikhantering

All extern trafik passerar genom route 53, WAF, Loadbalancer innan de når de interna resurserna. Detta skapar ett kontrollerat trafikflöde där endast godkänd trafik tillåts nå webbtjänsten.

Kommunikationen mellan resurser internt sker huvudsakligen via privata nätverk och VPC Endpoints istället för att passera över internet. Som exempel är S3 Gateway Endpoint ett sätt att möjliggöra kommunikation mellan EC2 instansen och S3-bucket utan att låta trafiken passera internet. Aurora databaserna kommunicerar också internet via AWS "rygggrad" och passerar inte ut via internet.

NAT Gateway tillåter EC2 instansen att initiera utgående trafik vid behov av systemuppdateringar och liknande men annars sker all trafik mellan enheter i nätverket internt.

Alla av nätverkets enheter påverkas av Security Groups (SG) som är konfigurerade att tillåta eller blockera trafik in eller ut från enheterna i sig. Detta innebär att t.ex. EC2-instanserna har en säkerhetsgrupp som bara tillåter trafik från Application load Balancer av en specifik sort (protokoll) på en specifik port. Alla dessa säkerhetsgrupper är konfigurerade att endast tillåta trafik från pilarna som kan ses i diagrammet i Del-2.

Kryptering och Skydda av Data

Kryptering av information används både vid lagring och överföring. Både S3-Bucket och Aurora databaser konfigureras med server-side encryption för att undvika att data sparas i klartext. Kommunikation inom nätverket krypteras även av AWS via deras egna AWS KMS kryptering. Övrig kommunikation sker via HTTPS-trafik vilket är krypterat av TLS.

Säker Administration

CloudCorp:s tidigare miljö hade SSH öppet mot internet, vilket tillåter vem som helst att försöka logga in via SSH och därifrån försöka administrera miljön. Detta vill vi undvika och har där för valt att använda AWS SSM istället. Detta innebär att vi kan stänga port 22 mot internet och ha administratörer administrera EC2 instanserna säkert via SSM. På så sätt har vi tagit bort en attackyta och minskar hotaktörers förmåga att attackera miljön.

Del 4 – Implementation

I denna del beskrivs hur den nya molnarkitekturen implementeras för att ersätta den osäkra miljön, tidigare använd av CloudCorp. Implementationen genomförs stegvis med regelbundna tester av implementerade delar för att säkerställa att konfigurationer är fungerande.

Nätverksinfrastruktur

Det första steget i implementationen är att skapa ett Virtual Private Cloud (VPC) i AWS där nätverket kommer att finnas. VPC konfigureras med adressen 10.0.0.0/16 för att ge tillräckligt med IP-adresser för resurser och enheter inom nätverket. Till denna VPC skapas flera subnät, 1 publikt och 2 privata per AZ (2 st), som kommer innehålla företagets privata och publika resurser.

Ytterligare en VPC skapades i en annan region med adressen 10.1.0.0/16, och ska innehålla 1 publikt subnät och två privata, men endast en AZ.

Därefter skapas en Internet Gateway till båda våra VPC:s som tillåter nätverken att kommunicera med internet. Efter Internet Gateway placeras en Webb Application

Firewall (WAF) som kontrollerar och skannar trafiken innan det tar sig in i nätverket, och stoppar de vanligaste typer av attacker som XSS, DDOS och SQL-injektioner.

Publika Subnät

Här placeras en Application Load Balancer och kopplas till de publika subnäten i samma region. Denna enhet är konfigurerad till att ta emot HTTPS trafik, distribuera trafik mellan de två olika EC2 instanserna (webbtjänsterna) och kontrollerar trafiken en sista gång innan den når de privata subnäten. Denna Application Load Balancer kan endast vidarebefordra trafik till EC2-instanserna och skicka trafik tillbaka ut via Internet Gateway:en.

I de publika subnäten placeras också en NAT Gateway, som tillåter EC2-instanserna att hämta hem uppdateringar vid behov.

Privata Subnät (App)

I dessa privata subnät placeras webbtjänsten, EC2-instansen. Denna instans har ingen publik IP-adress och kan endast ta emot trafik från Application Load Balancer. Dessa enheter konfigureras för att tillåta SSM och tillåts även kommunicera med nätverkets Backend funktioner (Lambda) via Private API Gateway Endpoints, som ser till att trafiken inte tar sig ut via internet och istället tar sig igenom AWS interna nät.

För att SSM ska fungera så placeras även SSM Interface Endpoints här som tillåter alla SSM funktioner att fungera.

Privata Subnät (Data)

För datalagring implementeras Amazon Aurora Serverless v2 i de privata data subnäten. Dessa databaser konfigurerades med Multi-AZ failover, automatisk skalning och kryptering för att säkra att företagets kunddata förblir säker och ersätter företagets föregående lösning av att lagra all kunddata i en S3-Bucket. Dessa databaser tillåter endast trafik från EC2-instanserna/Backend (Lambda). Databasen i standby-regionen fungerar främst som en Global Database Replica i nödfall.

S3-Bucket

Företagets tidigare osäkra S3-Bucket har återanvänts med en ny, säker konfiguration (block public access) som tillåter för lagring av övrig kunddata, så som bilder och filer istället för att placera all form av kunddata i den. Denna är nu också krypterad (server-

side encryption). Den har i övrigt Policies som begränsar åtkomst. För att undvika att trafik mellan EC2-instanser och denna S3-bucket går över internet har en S3-Gateway Endpoint implementerats inom VPC:n.

IAM

Flera IAM roller skapas runt principen Least Privilege för att minska risken för obehörig åtkomst. Separata roller skapas till EC2-instanser, Lambda-funktioner, administrativa användare. Dessa roller tilldelas endast de rättigheter som krävs för att kunna utföra sina funktioner.

I övrigt aktiveras Multi Factor Authentication på alla administrativa konton som ett extra skyddslager. IAM policies används även för att begränsa åtkomsten till företagets känsliga resurser som databaser och S3-Bucket.

Lambda Backend

AWS Lambda implementeras som webbtjänstens Backend-logik och hanterar automatiserade processer som autentisering osv. Denna Backend kommunicerar med EC2-instanserna och Aurora databaserna via en Private API Gateway Endpoint för att undvika att kommunikationen passerar genom internet och istället via AWS interna "rygggrad".

Route 53

En Route 53 har implementerats/konfigurerats för att kunna dirigera trafik mellan de två olika regionerna i det eventuella fallet att en region slutar fungera.

Del 5 - Säkerhetsanalys

Trots den nya och förbättrade arkitekturen så finns det eventuella säkerhetsrisker som skulle kunna påverka denna konfiguration. Ingen miljö är helt säker och är beroende på att den används rätt och är konfigurerad och administrerad på rätt sätt.

Risk 1 – IAM & Övriga Felkonfigurationer

Den nya arkitekturen bygger på att Security Groups (SG) och IAM roller fungerar som de ska för att kunna säkerställa att företagets resurser (Aurora, S3-Bucket) följer de tre

säkerhets principer detaljerade i CIA-triaden. Om en IAM roll har fått överflödiga behörigheter och komprometteras kan en hotaktör med tillgång till kontot orsaka större skada till system och nå resurser som den annars inte skulle ha tillgång till med en korrekt konfigurerat IAM roll.

För att undvika att detta händer måste regelbundna revisioner utföras, och detta kan underlättas av AWS egna tjänst för just detta, AWS IAM Access Analyzer.

Risk 2 – NAT Gateway

NAT Gateway används för att tillåta en privat resurs utåtgående internet åtkomst utan att exponera de publikt. Detta används främst för att ladda ner uppdateringar och på så sätt hålla systemen säkrare. Detta kan också användas för att skada dessa interna resurser. Om en Hotaktör får tillgång till en EC2-instans skulle denna NAT Gateway tillåta nedladdningen av skadlig programvara rakt in i webbtjänsten. En NAT Gateway har också stora kostnader associerade med större mängder av data så om ett intrång inte märks av skulle en hotaktör kunna ladda ner större mängder data, inte bara för att påverka webbtjänsten i sig, men för att tvinga företaget att betala större mängder pengar för den trafiken som har gått igenom NAT Gateway utan deras medvetande.

För att undvika detta så rekommenderas att stänga av eller ta bort NAT Gateway när den inte är under användning.

Risk 3 – AWS Beroende

Denna nya lösning är högst beroende av AWS infrastruktur och tjänster för att fungera korrekt. Om AWS drabbas av driftstörningar eller andra sorts avbrott kommer det att påverka företagets webbtjänst även om arkitekturen är skapad med redundans i åtanke. Arkitekturen är fortfarande beroende av AWS centrala tjänster för att fungera. Några exempel på detta är Route 53, IAM, S3, Aurora och SSM.

Just på grund av detta så rekommenderar jag att ha en databas på kontoret som kopierar från AWS Aurora databaser som fungerar som en sista säkerhetsåtgärd så det finns en fysisk kopia av all kunddata vid extrema fall där hela system måste byggas om eller om man vill byta ut till en helt fysisk tjänst igen.

Risk 4 – Webbapplikation Kompromettering

Faktumet att det finns en WAF och en Application Load Balancer betyder inte att webbtjänsten är helt säker. Säkerhet i infrastrukturen skyddar automatiskt mot osäker kod eller logiska sårbarheter i en applikation.

Detta innebär att attacker som SQL-injektion, XSS och felaktig autentisering fortfarande kan påverka företagets webbtjänst.

Detta kan endast åtgärdas genom att genomföra regelbundna säkerhetstester och följa säkra utvecklings principer för att motverka dessa attacker.

Risk 5 - Bristande Övervakning & Loggning

I den förbättrade arkitekturen finns ingen aktiv övervakning eller loggning som skulle kunna ge väsentlig information om hur mycket trafik som webbtjänsten får och vilken sorts funktioner som används mest. Detta skulle också ge en inblick i hur en hotaktör gjort för att försöka attackera nätverket och möjligtvis se vilka trender och potentiella attackvägar som hotaktörer försöker utnyttja för att vara förberedd för dessa i framtiden.

Detta kan enkelt åtgärdas av att använda sig av AWS egna lösningar, så som CloudTrail eller CloudWatch.

Resonemang Kring Säkerhetsrisker

Den mänskliga faktorn fortsätter att vara den stora boven i säkerhetsarbetet där arkitekturer och system kan vara robusta och skyddade men enstaka felkonfigureringar får stora konsekvenser som sällan kan åtgärdas i stunden. Just därför är det av största betydelse att förstå att säkerhet är ett kontinuerligt arbete där teknik, processer, rutiner och människor måste samverka för att minska risken för framtida incidenter.

Del 6 - Kostnad och molnmodeller

Följande beskriver olika sorters molnmodeller och hur kostnader fungerar i relation till molntjänster. I övrigt beskrivs också hur man undviker att betala för mycket med kostnadsoptimering.

SaaS (Software as a Service)

Software as a Service innebär att färdiga applikationer levereras via internet och används direkt av kunden utan att behöva hantera infrastruktur eller plattform. Detta

innebär att företag kan fokusera på att leverera sin webbtjänst istället för att behöva hantera installation och underhåll men har då liten kontroll över systemets funktionalitet och säkerhet.

IaaS (Infrastructure as a Service)

Infrastructure as a Service innebär att molnleverantören tillhandahåller infrastruktur som servrar, lagring och nätverk. Kunden i sig ansvarar för operativsystem, applikationer och administration av dessa resurser. Detta ger kunden möjligheten att anpassa miljön baserat på behov med nackdelen att kunden is stort ansvarar för säkerheten.

PaaS (Platform as a Service)

Plattform as a Service innebär att molnleverantören hanterar större delar av infrastrukturen och plattformen medan kunden fokuserar på applikationer och data. Denna tjänst automatiserar mycket av driften men nackdelen att kunden har mindre kontroll över underliggande infrastruktur.

Kostnader

Till skillnad från mer traditionella datacenter bygger molntjänster på en modell där man betala för de resurser som används. Man kan säga att man betalar för enheter och belastning. Som exempel, är en EC2-instans någon man betalar för både i mängd av instanser och hur mycket CPU och minnesanvändning som instansen använder.

Denna formel appliceras på varje del av molnet så som, nätverkstrafik, lagring, övervakning, loggning och på så sätt beräknar kostnaden.

Detta innebär dock att det finns kostnadsrisker associerade med molnmiljöer. Den första är att resurser dimensioneras större än nödvändigt vilket resulterar i stora kostnader för något som inte används. Detta skulle kunna vara stora Databaser eller EC2-instanser som tar upp mycket mer plats än nödvändigt. Efter som man betalar för den mängd trafik som passerar genom nätverket så kan det finnas scenarion där hotaktörer skickar stora mängder trafik för att driva upp kostnader.

Dessa kostnadsrisker kan dock åtgärdas genom att använda sig av automatisk skalning, som anpassar storleken på instanser och databaser baserat på behov/användning. Samt Rate Limiting som begränsar mängden trafik in i nätverket som stoppar attacker med hög trafik, som DDOS.

AWS har också verktyg som kan hjälpa till med att övervaka kostnader av molnmiljöer som till exempel CloudWatch.